



University of South Wales

Prifysgol De Cymru

Faculty of Computing, Engineering and Science

BSc Dissertation

Cybersecurity Challenges in Healthcare OT and IoMT Environments

Wail Hassan Ali

23111540

First Supervisor:	Rachael Medhurst
Second Supervisor:	Richard Ward
Year of Study:	2025-2026
Course:	BSc Applied Cyber Security

University of South Wales

Prifysgol De Cymru

Faculty of Computing, Engineering and Science

23111540

STATEMENT OF ORIGINALITY

This is to certify that, except where specific reference is made, the work described in this project is the result of the investigation carried out by the student, and that neither this project nor any part of it has been presented, or is currently being submitted in candidature for any award other than in part for the BSc award, Faculty of Computing, Engineering and Science from the University of South Wales.

Signed:  _____

Name: Wail Hassan Ali

Date: [12.04.2026]

Acknowledgements

I, Wail Hassan Ali, hereby want to thank Noroff and the University of South Wales for this opportunity I have received to be able to participate in and complete this Bachelor's degree. I also want to thank my supervisors Rachael Medhurst and Richard Ward for all the support they have given me, their time, and the good feedback, as well as keeping me on track.

Last but not least, I want to thank my family for what they have gone through during this period, and for never stopping believing in me during this journey.

Abstract

Cybersecurity challenges in healthcare are becoming more visible, particularly in systems based on operational technology (OT) and Internet of Medical Things (IoMT). These systems are often required to run continuously, which limits how security measures can be applied in practice.

The study uses a qualitative approach based on literature, reported cyber incidents, and a review of selected cybersecurity frameworks. A small proof-of-concept simulation was also used to explore how these issues may appear in practice.

The findings show that internal access, limited network segmentation and a lack of active monitoring can create security risks in connected healthcare systems. These issues are not only technical but also linked to how systems are used in daily operations.

The study also shows that existing frameworks do not always reflect actual conditions in healthcare environments. In practice, applying recommended security controls in these environments is not always straightforward.

The findings suggest that cybersecurity in healthcare depends not only on technical issues, but also on how systems are used in everyday work.

Table Of Contents

STATEMENT OF ORIGINALITY	1
Acknowledgements	2
<i>Abstract</i>	3
1. Introduction	6
2. Literature Review	9
2.1 Introduction	9
2.2 OT and IoMT in Healthcare	9
2.3 Common Vulnerabilities in OT and IoMT	13
2.4 Documented Cyber Incidents in Healthcare	14
2.5 Frameworks and Regulations (NIS2, GDPR, ISO, MDR, NIST)	15
2.6 Summary and Research Gap	16
3. Methodology	17
3.1 Research design	17
3.2 Literature and incident analysis	18
3.3 Proof-of-Concept simulation	20
3.4 Tools and environment	22
3.5 Framework and regulation evaluation	23
3.6 Ethical considerations	25
3.7 Design of the Proof-of-Concept	26
4. Findings	28
4.1 Introduction	28
4.2 Proof-of-Concept Environment	28
4.3 Scenario 1: Internal Access	29

4.4	Scenario 2: Limited Network Segmentation	31
4.5	Scenario 3: Limited Detection	32
4.6	Summary of Findings	32
5.	Discussion	33
5.1	Introduction	33
5.2	Discussion of Scenario 1 – Internal Access	33
5.3	Discussion of Scenario 2 – Network Segmentation	35
5.4	Discussion of Scenario 3 – Detection and Monitoring	36
5.5	Implications for Healthcare Organisations	37
5.5.1	Internal Access	38
5.5.2	Network Segmentation	38
5.5.3	Detection and Monitoring	38
5.6	Limitations of the Study	39
5.7	Evaluation of the Proof-of-Concept	39
6.	Conclusion	41
	References	43

1. Introduction

Healthcare is becoming increasingly digital. Hospitals now rely on connected technologies not only for administration, but also to manage medical equipment that plays a direct role in patient care (European Union Agency for Cybersecurity, 2023).

Clinical systems do not behave like ordinary IT systems. Taking medical equipment offline is rarely an option, as patients depend on it. Updates are often pushed back when clinical work is ongoing (National Institute of Standards and Technology, 2022). Because of this, known vulnerabilities can remain unaddressed for longer periods.

Medical devices add another layer of difficulty. They are often used for many years and are not updated frequently. In many cases, they run software that healthcare organisations have limited control over. Fixing a vulnerability often depends on the vendor. In some cases, updates must go through certification or approval processes before they can be applied (U.S. Food and Drug Administration, 2023). This takes time, which increases the period of exposure.

Weak authentication, limited network segmentation and poor logging are frequently seen in connected healthcare systems (European Union Agency for Cybersecurity, 2023).

Cyber incidents still hit healthcare organisations regularly, disrupting day-to-day operations and cutting off access to patient records (European Union Agency for Cybersecurity, 2023). Routine procedures get delayed, and because healthcare is critical infrastructure, the impact rarely stays contained within a single organisation. Hospitals cannot simply shut down while they deal with an attack, which makes the whole thing considerably harder to manage.

Many of these systems were not originally designed for network connectivity. As more devices are connected, a vulnerability in one system can affect others. Issues may spread beyond the originating system.

Cybersecurity frameworks and regulations are designed to support healthcare organisations. However, most are based on traditional IT environments. They assume systems can be patched or isolated quickly when issues arise. In healthcare, this is not always realistic. Equipment needs to stay operational. Changes often require coordination with vendors. Some devices are approved under specific configurations, which limits how updates can be applied. What appears straightforward in theory can take much longer in practice.

There is often a difference between what regulations expect and what can realistically be achieved in clinical environments. Meeting compliance requirements does not necessarily mean that underlying risks have been removed.

Research has identified vulnerabilities and reported cyber incidents in healthcare. There is less focus on how technical issues, everyday operational constraints and regulations interact in real clinical settings.

Healthcare technology does not operate independently. It exists within organisational structures, clinical workflows and regulatory systems. Cybersecurity in healthcare is not only a technical challenge. It also involves operational and organisational factors. Hospitals deal with patient safety, continuity of care and compliance requirements at the same time. This shapes how security decisions are made.

This study brings together technical analysis, incident review and an evaluation of existing frameworks to develop a more grounded understanding of cybersecurity in healthcare OT and IoMT environments.

This dissertation examines documented vulnerabilities and cyber incidents affecting healthcare OT and IoMT systems. It also evaluates selected cybersecurity frameworks and regulations to assess how well they reflect the identified risks. In addition, a controlled proof-of-concept simulation is used to show how selected vulnerabilities may appear in practice and how they can be reduced within an isolated environment.

The aim of this study is to examine common cybersecurity vulnerabilities in OT and IoMT systems used in healthcare and to assess how they are addressed within selected cybersecurity frameworks and regulations.

To support this aim, the study has the following objectives:

- To identify common vulnerabilities in healthcare OT and IoMT systems through literature and incident analysis.
- To examine how these vulnerabilities have been exploited in documented healthcare cyber incidents.
- To evaluate selected cybersecurity frameworks and regulations in relation to identified risks.
- To demonstrate selected vulnerabilities within a controlled simulation environment.

This study is guided by the following research questions:

- What cybersecurity vulnerabilities are common in OT and IoMT systems used in healthcare?
- How have cyber incidents used these vulnerabilities in healthcare environments?
- Do existing cybersecurity frameworks and regulations cover OT and IoMT related risks?
- How can selected vulnerabilities be shown and reduced in a controlled simulation environment?

The dissertation is organised into six chapters. Chapter 2 covers the literature review. Chapter 3 describes the research method and simulation environment. Chapter 4 presents the findings. Chapter 5 discusses the results and their implications. Chapter 6 concludes the study and highlights areas for further research.

Together, these questions and objectives guide the structure of the study. The following chapter reviews existing literature to provide a foundation for understanding cybersecurity challenges in healthcare OT and IoMT environments.

2. Literature Review

2.1 Introduction

Healthcare organisations use OT and IoMT systems as part of routine clinical operations. The literature discusses cybersecurity challenges in these systems, focusing on vulnerabilities, reported incidents and regulatory requirements (European Union Agency for Cybersecurity, 2023) (Kumar, et al., 2023)

Much of the literature examines these areas separately. Technical studies often focus on identifying specific weaknesses. Regulatory documents mainly describe compliance requirements at an organisational level. While both perspectives are relevant, they are often discussed separately and not fully examined in relation to real healthcare practice. This makes it difficult to understand how these issues interact in environments where technical, operational and regulatory factors are present at the same time.

This chapter reviews existing research on OT and IoMT systems in healthcare, common cybersecurity vulnerabilities, documented incidents and applicable frameworks and regulations. The aim is not only to describe existing knowledge, but to assess how these areas relate to each other and to identify limitations in how healthcare cybersecurity is addressed in the literature. This also provides a basis for the later analysis by linking these areas to practical observations.

2.2 OT and IoMT in Healthcare

Healthcare systems depend on more than standard IT solutions. In hospitals, many technologies are directly involved in physical processes and patient care. These systems are used during diagnosis, treatment, and daily clinical work, not only for administration. Because of this, technology in healthcare cannot be treated as background support in the same way as traditional IT systems.

Operational technology is used to describe systems that control or monitor physical equipment. In a healthcare environment, this includes imaging machines, laboratory systems, and building management technology. These systems are required to function continuously to

support clinical work. Unlike standard IT systems, they are designed mainly for availability and safe operation rather than flexibility or frequent updates.

OT systems are often built for long-term use. In many cases, these systems are also integrated into larger hospital infrastructure. This includes connections to central systems such as electronic health records and monitoring platforms. Because of this, changes to one system can affect others. This increases the need for stability, which can limit how often systems are modified.

OT systems may also use specialised hardware and software that are not easily replaced. This can make it difficult to apply standard IT security solutions. In some cases, security updates may not be supported at all.

In healthcare, equipment is expected to remain in operation for several years. Because of this, systems are not always replaced or updated regularly. This can make it harder to introduce new security measures over time.

OT systems in healthcare usually run continuously. Stopping or changing them can create operational and safety risks. This limits how traditional security measures, such as regular patching or system isolation, can be applied in practice. Even short interruptions can affect clinical work (National Institute of Standards and Technology, 2022). As a result, hospitals update or reconfigure these systems less frequently than standard IT environments.

In hospital environments, different systems are often connected so information can be shared more easily. If one system has a failure or a security issue, other systems can be affected. This is why cyber incidents in healthcare can cause bigger problems (European Union Agency for Cybersecurity, 2023).

A further issue is the age of much of the equipment used in hospital environments. The literature is consistent on this point, but offers limited guidance on how organisations should prioritise risk when multiple legacy systems are present simultaneously. Many systems are based on older technology and cannot be updated easily. This increases the likelihood that known vulnerabilities remain present in operational environments for extended periods.

Limited options for system changes and strong dependence on vendors often delay security improvements and responses to newly identified vulnerabilities. This creates reduced organisational control over technical risk mitigation (European Union Agency for Cybersecurity, 2023).

Alongside OT, the use of Internet of Medical Things devices has increased in healthcare environments. These devices are connected to networks and are used during normal clinical work. Examples include infusion pumps, patient monitoring systems, wearable devices, and implantable technologies. These devices are often used directly in patient care. Because of this, reliability is prioritised over flexibility. If a device stops working, it can affect treatment. This makes it difficult to apply changes that may interrupt operation.

In addition, many devices are configured in a fixed way after installation. This can limit how much they can be changed later. As a result, known weaknesses may remain in use.

IoMT devices are often connected to hospital networks to support patient care. These devices collect and share data as part of normal clinical work. Because they are connected, they also increase the number of entry points into the network. Continuous operation and large-scale deployment increase the number of components that need to be secured, which makes these devices more difficult to protect in practice (Kumar, et al., 2023).

Device lifespan is also mentioned in the literature. Many IoMT devices are used for several years as part of clinical infrastructure. These devices are approved for long-term use. Updates and system changes are limited. In addition, devices may be approved for use under specific conditions. This can limit how they are modified after deployment. Changes to software or configuration may require approval, which can delay updates. Known weaknesses can remain in these devices for years. This makes patch-based security approaches used in traditional IT harder to apply (U.S. Food and Drug Administration, 2023).

Medical devices often use third-party software. In many cases, this software is built into the device. Hospitals do not manage it directly. This also creates a dependency on external vendors. Healthcare organisations may need to wait for updates or fixes from suppliers.

This can slow down response to known vulnerabilities. This makes it hard to know how the software is developed or updated. Vulnerabilities can stay in the device even when local

security controls are used (U.S. Food and Drug Administration, 2023). Kumar et al. (2023) highlight this vendor dependency as one of the most underexplored areas in IoMT security research, noting that most studies focus on device-level vulnerabilities rather than the supply chain risks that come with embedded third-party software.

In addition, several basic security controls are still missing in many environments. Weak authentication and limited logging are reported for many connected medical devices. This reduces visibility into system activity and limits the effectiveness of detection and incident response mechanisms. System activity is not always recorded in detail. Limited visibility can make it difficult to understand what is happening in the system. Without detailed logs, it is harder to detect unusual behaviour or investigate incidents. As a result, investigation and response can be more difficult when incidents occur (U.S. Food and Drug Administration, 2023).

Many hospital systems are used directly during patient treatment. They are not designed to be taken offline. These systems support daily clinical work. For this reason, changes to system configuration are often limited. This affects how security measures are applied in hospitals (National Institute of Standards and Technology, 2022) (European Union Agency for Cybersecurity, 2023) (Kumar, et al., 2023).

Several studies also describe how security practices differ between healthcare environments and traditional IT settings. While ENISA and NIST both highlight this gap, they approach it differently. NIST tends to focus on technical controls and risk management processes, while ENISA places more emphasis on the organisational and operational factors that shape how security is applied in practice (National Institute of Standards and Technology, 2022) (European Union Agency for Cybersecurity, 2023). Neither fully addresses how these two dimensions interact in clinical environments.

Together, these characteristics help explain why healthcare OT and IoMT systems remain exposed to persistent security weaknesses. These weaknesses are examined in more detail in the following section.

2.3 Common Vulnerabilities in OT and IoMT

Recurring weaknesses appear in OT and IoMT systems used in healthcare environments (OWASP Foundation, 2022) (European Union Agency for Cybersecurity, 2023). Many of these weaknesses are linked to the operational characteristics described in the previous section.

Limited patching and update management are commonly reported issue. Many OT and IoMT systems operate on fixed software versions for long periods. This increases the chance that known vulnerabilities remain exploitable over time. Updates are often delayed or avoided because systems need to remain stable and continuously available during clinical use (OWASP Foundation, 2022). As discussed in Section 2.2, this makes traditional patch-based approaches harder to apply in practice. OWASP and ENISA both identify patching as a critical issue, but neither provides specific guidance on how healthcare organisations should manage patch cycles when systems cannot be taken offline. This gap between identifying the problem and offering practical solutions is a recurring limitation in the literature.

Limited network segmentation is also observed in healthcare environments. In some cases, OT and IoMT systems are placed on the same networks as general IT systems. This increases exposure, as a security issue in one part of the network may affect connected clinical systems (OWASP Foundation, 2022). If segmentation is difficult, the risk often remains. This means that a single compromised system can affect multiple connected devices. While network segmentation is widely recommended across frameworks, the literature offers little on how it should be prioritised when clinical systems depend on constant communication. ENISA acknowledges this tension but stops short of offering concrete steps for environments where full segmentation is not realistic (European Union Agency for Cybersecurity, 2023).

Limited monitoring and logging are also common issues. Many OT and IoMT systems generate little security-related log data, or logging is not enabled by default. Unusual activity may go unnoticed, making incidents harder to investigate. This can delay detection and response during an incident (OWASP Foundation, 2022). Kumar et al. (2023) note that monitoring in IoMT environments is particularly difficult because many devices were not designed with security visibility in mind. This points to a design-level problem that cannot be resolved through configuration alone.

These vulnerabilities are reflected in documented cybersecurity incidents in healthcare environments and are examined in the following section. These vulnerabilities are often not isolated. They can appear together in the same environment. This can increase the overall level of risk.

In practice, these weaknesses can reinforce each other. For example, limited segmentation combined with weak authentication can make it easier to move between systems. This increases the overall exposure of the environment.

2.4 Documented Cyber Incidents in Healthcare

Healthcare organisations have been dealing with cybersecurity incidents for years (European Union Agency for Cybersecurity, 2022) (European Union Agency for Cybersecurity, 2023). Hospitals, clinical systems and medical devices used in everyday care have all been caught up in them. In several cases, staff lost access to patient information while treatment was still going on, and day to day work had to stop.

WannaCry in 2017 showed what a cyberattack can actually do to a health service. Across England, 81 NHS trusts were hit, and a third of NHS England trusts had their day-to-day work thrown into disarray (National Audit Office, 2017). Appointments were cancelled, ambulances turned away and staff went back to pen and paper just to keep things moving. The attack came through older Windows systems that nobody had got around to patching, despite a fix being available for weeks before the attack hit. This is the same problem described in section 2.3, where updates get delayed because clinical systems are hard to take offline, even for a short time.

The incident also showed what happens when hospital systems are closely connected. Once one part of the network was hit, the disruption spread to others. This links back to the segmentation issues raised in section 2.2. There are also reported cases of unauthorised access, including compromised accounts and systems left exposed through hospital networks (European Union Agency for Cybersecurity, 2023). These reflect the weaknesses in authentication and monitoring covered in the previous section, and show that those weaknesses get exploited in practice, not just in theory.

These incidents make the point clearly enough. The vulnerabilities described in the literature are not abstract. They have disrupted real hospitals, affected real staff and in some cases reached patients directly.

2.5 Frameworks and Regulations (NIS2, GDPR, ISO, MDR, NIST)

Several frameworks and regulations are used in healthcare cybersecurity, but none of them were written specifically for OT or IoMT systems.

NIST SP 800-82 covers industrial control systems and how they sit differently from standard IT (National Institute of Standards and Technology, 2023). In healthcare, this difference matters because these systems need to keep running while patients are being treated. What it does not get into is how certification requirements can get in the way of making changes to devices that are already deployed.

ISO/IEC 27001 is widely used for information security management (International Organization for Standardization, 2022). In healthcare it mostly gets applied to IT systems and data. Medical devices and OT systems fall outside what it was designed for.

NIS2 brings healthcare into scope and sets out what organisations need to do around cybersecurity and incident reporting (European Union, 2022). It works at an organisational level though, and gives limited detail on how clinical systems should be protected in practice.

GDPR covers personal data, which in healthcare means most of what is stored or shared digitally about patients (European Union, 2016). It is focused on privacy and data protection. Security of connected devices or OT infrastructure is not its main focus.

MDR applies to medical devices, including those connected to hospital networks (European Union, 2017). It is mainly about getting devices approved safely before they go into use. What happens to security after deployment is largely left open.

Each of these frameworks covers something useful, but none of them were written around how clinical environments actually work. Things like system availability, older infrastructure and vendor dependencies rarely get the attention they deserve.

2.6 Summary and Research Gap

The literature covers a lot of ground when it comes to cybersecurity in healthcare. OT and IoMT systems are well described, recurring vulnerabilities are documented, and cyber incidents have been reported across different healthcare settings (European Union Agency for Cybersecurity, 2022) (National Institute of Standards and Technology, 2023). There is no shortage of material on what the problems are.

What is harder to find is research that looks at how these things connect in practice. Technical studies tend to look at specific vulnerabilities on their own (OWASP Foundation, 2022). Regulatory documents focus on what organisations are required to do (European Union Agency for Cybersecurity, 2022). Incident reports describe what went wrong. Few studies look at how these factors play out together in real clinical environments, where operational constraints, technical weaknesses and regulatory expectations exist side by side (Kumar, et al., 2023).

This matters because cybersecurity problems in healthcare rarely have a single cause. A vulnerability exists in a system that cannot easily be taken offline, within an organisation that depends on vendors for fixes, covered by frameworks that were not written with any of that in mind (National Institute of Standards and Technology, 2022). Looking at just one piece of that without the rest does not give the full picture.

Weak authentication, limited network segmentation and delayed patching keep coming up in the literature (European Union Agency for Cybersecurity, 2023). What gets less attention is why these weaknesses stick around in environments where clinical demands and regulatory requirements shape every decision.

This study tries to address that gap. By combining literature and incident analysis with a proof-of-concept simulation and a structured review of selected frameworks, it looks at how these factors come together in practice rather than treating them separately. The next chapter sets out how that was done.

3. Methodology

3.1 Research design

This study takes a qualitative approach. The work is based on a literature review, analysis of reported cyber incidents, evaluation of cybersecurity frameworks, and a technical proof-of-concept simulation. Qualitative research is used to understand complex situations rather than produce numerical results (Creswell & Creswell, 2018). In this study, the focus is on how operational constraints, vulnerabilities and regulatory frameworks interact in healthcare environments. These are not independent factors, and they often influence each other in practice. Examining these relationships requires interpretation of documented evidence rather than statistical analysis.

A quantitative design was not suitable, as the project does not involve measurable variables or large datasets. The focus is instead on analysing documented material and identifying patterns across literature, incidents and regulatory sources. This makes it possible to examine how vulnerabilities and operational constraints appear in real healthcare environments, rather than in isolated technical conditions. Case-based and document-based approaches are often used in cybersecurity research to understand system behaviour and threat development (Yin, 2018).

The proof-of-concept simulation complements the document analysis by allowing selected vulnerabilities to be examined in a controlled setting. This makes it possible to observe how technical weaknesses may appear when systems are connected within the same network environment. It also provides a practical way to relate findings from the literature to observable system behaviour. Simulation-based approaches are widely used in information security testing, particularly where testing on live systems would not be appropriate or safe (National Institute of Standards and Technology, 2008).

The research design is exploratory. Rather than testing a specific hypothesis, the study looks at how operational constraints, vulnerabilities and regulatory frameworks connect in healthcare environments. Cybersecurity issues in healthcare rarely come from a single factor. They usually involve a mix of technical, organisational and regulatory elements that interact in different ways. An exploratory approach is used to examine how these factors relate to each other (Creswell & Creswell, 2018).

The design combines document analysis with a controlled technical simulation. This allows the study to consider both documented evidence and observed technical behaviour. Instead of isolating one variable, the study looks at several elements together, including operational limits, technical weaknesses and regulatory requirements. This reflects how cybersecurity risks appear in real healthcare environments, where different constraints exist at the same time (Yin, 2018).

Findings from the literature were compared with documented incidents and results from the simulation. This made it easier to see whether similar vulnerabilities appeared across different sources. Using more than one source gives a better overall view of the issues, rather than relying on a single type of data (Creswell & Creswell, 2018).

The study focuses on understanding how different factors are connected rather than measuring them. This means that the results are based on interpretation rather than numerical data. The aim is to describe how these issues appear and relate to each other in a healthcare setting.

The exploratory design allows flexibility when examining complex environments such as healthcare. Instead of focusing on a single variable, it considers how different elements interact. This is useful when studying systems that involve both technical and organisational factors.

3.2 Literature and incident analysis

A literature review was carried out to identify research related to OT systems, IoMT devices, cybersecurity vulnerabilities and healthcare cyber incidents. Sources included academic publications, industry reports, government publications and regulatory documents. Using different types of sources made it possible to include both academic research and practical insights into cybersecurity issues affecting healthcare systems (Kitchenham, 2007). Sources were selected based on relevance to healthcare OT and IoMT environments, as well as credibility and the level of technical or regulatory detail provided.

The search process used Google Scholar and academic databases such as IEEE Xplore. Keywords were based on combinations of terms such as “healthcare OT security”, “IoMT cybersecurity”, “medical device vulnerabilities” and “healthcare cyber incidents”. These terms helped identify studies addressing security risks in healthcare technologies. The search

was carried out in a structured way to keep the process transparent and reduce the risk of selection bias (Kitchenham, 2007).

Recent publications were prioritised to reflect current technological developments and regulatory changes. Some earlier sources were still included, particularly where they helped explain the background of the topic or the technologies involved.

Only sources written in English were included. Informal blogs, opinion-based articles and unverified online material were excluded to maintain credibility (Kitchenham, 2007).

Documented cyber incidents affecting healthcare organisations were also reviewed. Public incident reports, threat intelligence publications and security advisories from recognised organisations were used to identify common vulnerabilities and attack methods. These reports were examined to understand how incidents have affected healthcare organisations in practice.

Public reports do not always provide much technical detail. Some incidents are only described briefly (European Union Agency for Cybersecurity, 2022) (European Union Agency for Cybersecurity, 2023). This means that only incidents with enough technical detail were included.

Information from the literature was compared with documented incidents to check whether similar vulnerabilities appeared in both sources. These findings were later used to guide the proof-of-concept simulation and the evaluation of selected cybersecurity frameworks.

Not all sources provided the same level of detail. Some reports described incidents in general terms, while others included more technical information. Because of this, some interpretation was needed when comparing sources.

In addition, different types of sources were used. Academic studies often focus on theory, while reports from organisations describe practical situations. Combining these sources made it possible to see both perspectives.

The selection of sources was based on relevance rather than quantity. Some sources were more detailed than others, which influenced how they were used in the analysis. In some cases, multiple sources were used to support the same observation.

3.3 Proof-of-Concept simulation

A proof-of-concept simulation was developed to show how selected vulnerabilities in OT and IoMT environments can be exploited or reduced in a controlled setting. These vulnerabilities were identified in Section 2.3. The simulation was not intended to replicate a real hospital network, but to show how identified weaknesses could affect connected systems in a simplified environment. It was carried out in an isolated virtual setup so that no real healthcare systems were exposed to risk. Using isolated environments is standard practice in cybersecurity testing and vulnerability analysis (National Institute of Standards and Technology, 2008)

The simulation was used to observe how common cybersecurity weaknesses may appear in a simplified healthcare network. A simulated environment was chosen because testing security issues on real healthcare systems would not be appropriate or safe. A controlled virtual setup made it possible to explore these issues without affecting real systems or patient data.

Three scenarios were selected for the simulation. These focused on internal access, network communication between systems, and the visibility of system activity through logging. These scenarios were based on Sections 2.3 and 2.4. The scenarios were used to observe how these types of weaknesses may appear in a simple network environment.

The simulated environment represented typical healthcare network components, including OT-like systems and connected medical devices. The structure was kept deliberately simple to allow observation of technical behaviour without adding unnecessary complexity. The design focused on network connectivity, device communication and basic access control mechanisms, as these are often highlighted as areas of concern.

The simulation was used for analytical purposes rather than prediction. The scenarios were not intended to cover all possible risks, but to reflect commonly reported weaknesses in healthcare OT and IoMT environments. Security controls and risk management practices are often emphasised in critical infrastructure environments (National Institute of Standards and Technology, 2022).

During the simulation, technical behaviour was observed in relation to system access, network communication and possible lateral movement between components. The aim was to examine

how vulnerabilities identified in the literature could appear in a connected environment. Where possible, basic mitigation measures were also introduced to observe how system behaviour changed under modified conditions.

The simulation does not aim to replicate the full operational complexity of a real hospital infrastructure. Real healthcare environments include legacy systems, vendor constraints, certification requirements and human factors that were outside the scope of this setup. The purpose of the simulation was to help understand how vulnerabilities relate to network structure, rather than to act as a full operational model.

The simulated environment consisted of multiple virtual machines set up to represent separate network segments. One segment represented a general IT environment, while another represented OT-like components and connected medical devices.

The simulation did not focus on advanced exploitation techniques. Instead, it looked at how common configuration weaknesses could allow unauthorised access or movement between systems. The scenarios were kept technically simple so specific vulnerabilities could be observed without adding unnecessary complexity.

The objective was not to measure quantitative performance indicators, but to observe behavioural outcomes within the defined environment. This provides a qualitative view of how vulnerabilities may affect interconnected systems under controlled conditions.

Although the environment was simplified, the configuration and steps taken during the simulation were documented to support transparency. This makes it possible for the analytical process to be reviewed and potentially repeated under similar conditions. However, the findings remain limited to the defined setup and should not be generalised to all healthcare infrastructures.

The purpose of the simulation was not to test system performance, but to observe behaviour. This means that the results are based on how the system reacted under certain conditions, rather than on measurable performance metrics.

The scenarios were kept simple on purpose. A more complex setup could include more systems and variables, but this would make it harder to see what is actually happening. By limiting the setup, it becomes easier to observe specific behaviour.

3.4 Tools and environment

The simulation environment was built using VMware as the virtualisation platform to host the virtual machines used in the experiment. Separate virtual machines were configured to represent different roles within the simulated healthcare network. Kali Linux was used to represent an internal IT system within the network, while Ubuntu was configured to represent a clinical system connected to the healthcare environment.

Network segmentation was used within the virtual environment to separate the systems into different network areas. This allowed controlled communication between machines and enabled observation of how vulnerabilities could affect a clinical system when accessed from an internal IT segment. Basic internal routing and connectivity were configured to simulate communication typically found in connected healthcare infrastructures.

These tools were selected because they are widely used in cybersecurity testing and are suitable for controlled laboratory environments. The focus was on demonstrating how configuration weaknesses or insufficient segmentation could allow unauthorised access to the clinical system. Ubuntu, representing the clinical system, was monitored during testing to observe authentication behaviour, system responses and network communication.

VMware snapshots were used to restore the environment between test scenarios. This allowed repeated testing under consistent conditions and reduced the risk of configuration drift between experiments. No external networks, real patient data or production systems were connected to the simulation environment.

Virtualised lab environments are widely used in cybersecurity testing to ensure safe experimentation and controlled analysis (National Institute of Standards and Technology, 2008). The selected tools were chosen for stability and suitability within an isolated academic testing environment.

The tools used in the simulation are commonly used in cybersecurity education and testing. They are suitable for controlled environments where systems can be tested without affecting real infrastructure.

Using virtual machines also makes it possible to reset the environment and repeat tests. This helps maintain consistency across different scenarios.

3.5 Framework and regulation evaluation

Several cybersecurity frameworks and regulations were reviewed to see how they deal with OT and IoMT risks in healthcare. These included NIS2 (European Union, 2022), GDPR (European Union, 2016), the Medical Device Regulation – MDR (European Union, 2017), ISO/IEC 27001 (International Organization for Standardization, 2022), and selected NIST cybersecurity guidance (National Institute of Standards and Technology, 2022).

The review was qualitative. The goal was not to pick apart the legal wording, but to look at how each framework relates to the vulnerabilities identified earlier in the study. A document-based approach was used to structure the comparison (Kitchenham, 2007).

Each document was read individually before being compared against the others. Relevant sections on cybersecurity, risk management and system protection were noted, along with observations on how each framework handles the vulnerability areas discussed earlier. The same reference points were applied across all documents to keep the comparison consistent.

One aspect examined was whether the frameworks offer concrete technical controls or mainly focus on governance and reporting requirements. Particular attention was paid to whether OT and IoMT systems are explicitly mentioned, and whether practical constraints such as system availability or certification limitations are acknowledged.

The goal of the comparison was to identify potential gaps between documented vulnerabilities and what the frameworks actually cover. In some cases, governance requirements were clearly defined while technical guidance was limited. This kind of gap between regulatory expectations and technical practice has been noted in healthcare cybersecurity research (European Union Agency for Cybersecurity, 2023).

The proof-of-concept scenarios were also used as reference points during the evaluation. Instead of comparing frameworks only against abstract risks, the review also looked at how they relate to situations demonstrated in the simulation.

Scenario 1 involved unauthorised SSH access from an internal system to the simulated clinical system. It was used to assess whether the frameworks include requirements or guidance related to authentication, access control and internal network protection. The aim was not to test compliance, but to see whether such risks fall within each framework's stated scope.

Scenario 2 showed how limited network segmentation allowed lateral movement between systems within the same segment. This helped examine whether the frameworks address network separation and protection of connected systems, and whether such measures are framed as technical controls or broader governance requirements.

Scenario 3 highlighted the lack of active monitoring or alerting, even though SSH activity was logged locally. This was used to examine how monitoring, detection and incident response are addressed across the frameworks, including whether they emphasise real-time detection, reporting requirements or organisational responsibility. The comparison was not intended to judge whether the frameworks are sufficient in practice. It focused on how clearly the types of vulnerabilities demonstrated in the simulation are reflected in each document. This distinction is important, as frameworks may define responsibilities without specifying how they should be implemented technically. Findings from the literature review and incident analysis also informed the evaluation. Recurring issues such as weak authentication, limited segmentation and delayed patching were used as a starting point. Each framework was then checked to see if these issues appear in the text. Some frameworks address them clearly, while others only refer to them briefly or indirectly.

The evaluation also considered differences in legal status. EU regulations and directives set legal requirements for organisations within their scope (European Union, 2016) (European Union, 2017) (European Union, 2022). ISO/IEC 27001 and NIST guidance are different because they are not legally binding. They are often used as guidance when organisations

work with security practices (International Organization for Standardization, 2022) (National Institute of Standards and Technology, 2022).

The review was limited to the written content of the selected documents. National guidance, vendor documentation and internal organisational policies were not included. The analysis therefore reflects what is written in these documents, rather than how they are applied in practice.

This approach allows for a structured comparison of documented vulnerabilities, simulated behaviour and the scope of the selected frameworks. However, it remains a document-based analysis. It does not measure real-world compliance or enforcement, but provides an overview of how the frameworks relate to the technical risks identified in this study.

3.6 Ethical considerations

This project did not involve real patients, operational healthcare systems or live medical devices. All testing was carried out in an isolated virtual environment using simulated systems. No real patient data was collected or processed at any stage.

The proof-of-concept scenarios were developed to show technical behaviour in a controlled lab setting. They were not intended to represent a specific organisation or test real infrastructure. The focus was on understanding how vulnerabilities may appear in connected systems, rather than interacting with real environments.

All incident reports and regulatory documents used in the study were publicly available. No confidential information was accessed. The project followed standard academic research practices and remained within the defined testing environment.

The study focuses on general system behaviour rather than specific organisations. The aim is not to identify weaknesses in any real system, but to understand how similar issues may appear in controlled conditions.

3.7 Design of the Proof-of-Concept

This section describes the design of the proof-of-concept used in the study. The aim was to simulate a simplified healthcare environment to explore how cybersecurity issues may appear in practice.

The simulated environment was designed as a small healthcare network. It included a clinical system, an internal workstation and basic network connectivity between systems. The setup was intentionally kept small to allow controlled observation of system behaviour. A more complex environment could have been built, but this would make it harder to see how each part behaves. Keeping the setup smaller makes it easier to follow what happens in each scenario and how the system responds.

The design focused on three scenarios identified from the literature and earlier analysis:

- Internal access
- Network segmentation
- Detection and monitoring

Each scenario was selected because it reflects common cybersecurity challenges reported in healthcare environments. These are not isolated technical issues, but are often shaped by how systems are used in practice. This makes them relevant from both a technical and an operational perspective.

The internal access scenario looked at how a user with valid credentials could access a clinical system from within the network. The design allowed login using only basic credentials, without additional authentication controls. This reflects situations where systems rely mainly on username and password access. In healthcare, this is often linked to the need for quick access during clinical work. Because of this, stronger authentication is not always used. The scenario allows observation of how access can be established without additional checks, and how this may increase risk if credentials are misused.

The network segmentation scenario focused on communication between systems within the same network. Systems were placed in a shared network segment to observe how limited segmentation affects interaction. This reflects environments where systems are connected in a

more open structure rather than being strictly separated. In practice, healthcare systems often need to communicate, which can make strict segmentation difficult. The design therefore allows direct communication between systems, making it easier to observe how this affects behaviour.

The detection and monitoring scenario looked at how system activity is recorded and whether suspicious behaviour is detected. Logging was enabled, but no active monitoring tools were included. This reflects situations where organisations collect data but do not actively monitor it. Logs may exist, but they are not always reviewed. This allows activity to be recorded without immediate response. The scenario makes it possible to observe what happens when visibility exists, but detection is limited.

The proof-of-concept was kept simple. It does not represent a full healthcare system, but it makes it easier to observe specific behaviour across the scenarios. Real healthcare environments are more complex and include many interconnected systems, devices and network layers. Including all of this would make the setup harder to manage and reduce clarity.

Keeping the design simple also makes it easier to focus on each scenario. Each one can be observed without too many other factors affecting the result. This helps show how limited authentication or lack of segmentation can influence system behaviour.

At the same time, this approach has limitations. The environment does not reflect the full complexity of real healthcare networks. The aim was not to recreate a real system, but to focus on specific issues in a controlled setup. This makes it easier to see how these issues can occur in practice.

Overall, the design is a trade-off. It is not fully realistic, but it allows clearer observation of the selected scenarios without unnecessary complexity. The next chapter presents the findings from these scenarios.

The design also reflects a balance between realism and simplicity. While a more detailed setup could include more components, it would also make the analysis more complex. By focusing on fewer elements, it becomes easier to understand how specific issues develop.

4. Findings

4.1 Introduction

The simulation described in Chapter 3 provided a controlled environment to explore how the identified vulnerabilities could appear in practice. The following chapter presents the observations from the three scenarios.

This chapter presents the findings from the proof-of-concept carried out in this study. The practical work was used to observe how common cybersecurity issues may appear in a simulated healthcare setting. The findings are described based on what was observed, without further interpretation.

The results are organised into three scenarios related to internal access, network separation, and detection. These findings form the basis for the discussion in the next chapter.

4.2 Proof-of-Concept Environment

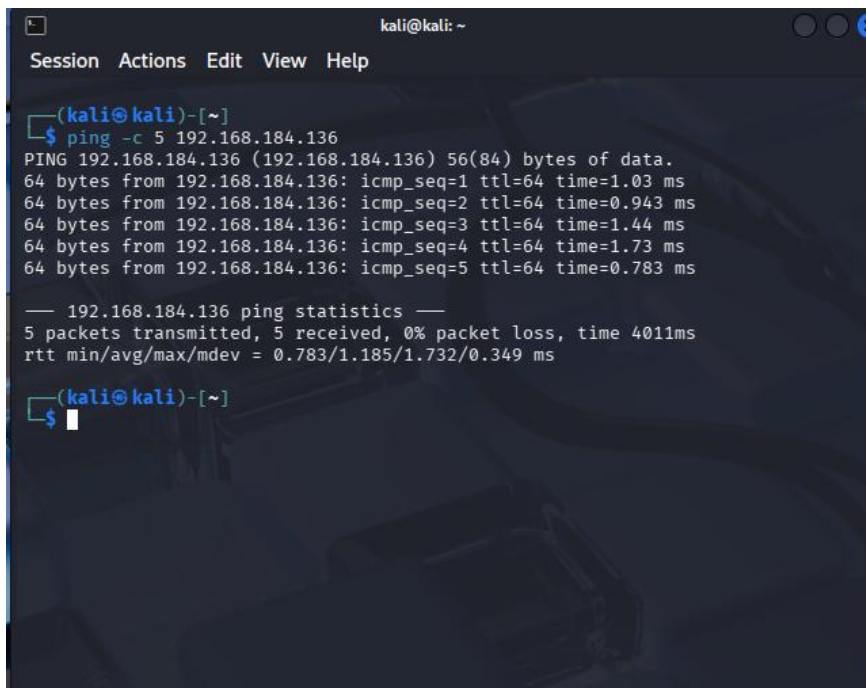
The proof-of-concept was conducted in an isolated virtual environment. No real healthcare systems or real data were used. The setup was not intended to replicate a real hospital environment, but to represent a simplified healthcare setting based on situations described in previous studies.

Two systems were included and connected to the same internal network. One system acted as an internal workstation, while the other represented a clinical or IoMT-related system. This reflects how internal systems and clinical devices may share network access in healthcare environments.

The environment was deliberately kept simple. No additional security controls were introduced, and only basic system configurations were used. This made it easier to focus on fundamental security issues rather than technical complexity.

4.3 Scenario 1: Internal Access

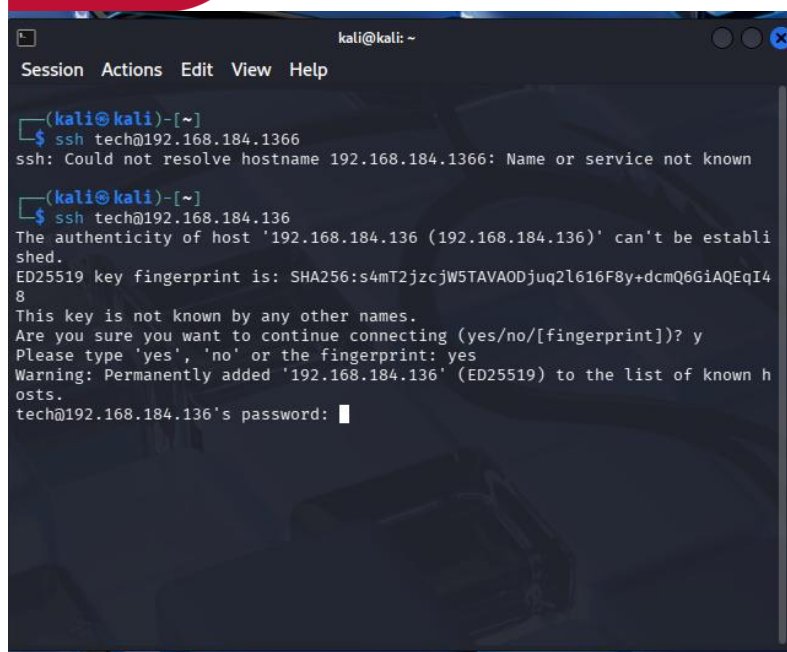
The first scenario focused on internal access to the clinical system. Access was attempted from the internal workstation using existing user login details. The connection was successful. No warning messages were shown during the access attempt. The system did not block the connection. After access was gained, the clinical system continued to operate normally. The system remained available, and no changes to normal operation were observed. This scenario shows that internal access to the clinical system was possible under the current setup.



```
kali@kali: ~  
Session Actions Edit View Help  
(kali@kali)-[~]  
$ ping -c 5 192.168.184.136  
PING 192.168.184.136 (192.168.184.136) 56(84) bytes of data.  
64 bytes from 192.168.184.136: icmp_seq=1 ttl=64 time=1.03 ms  
64 bytes from 192.168.184.136: icmp_seq=2 ttl=64 time=0.943 ms  
64 bytes from 192.168.184.136: icmp_seq=3 ttl=64 time=1.44 ms  
64 bytes from 192.168.184.136: icmp_seq=4 ttl=64 time=1.73 ms  
64 bytes from 192.168.184.136: icmp_seq=5 ttl=64 time=0.783 ms  
— 192.168.184.136 ping statistics —  
5 packets transmitted, 5 received, 0% packet loss, time 4011ms  
rtt min/avg/max/mdev = 0.783/1.185/1.732/0.349 ms  
(kali@kali)-[~]  
$
```

Figure 1: Network connectivity between the internal workstation and the clinical system

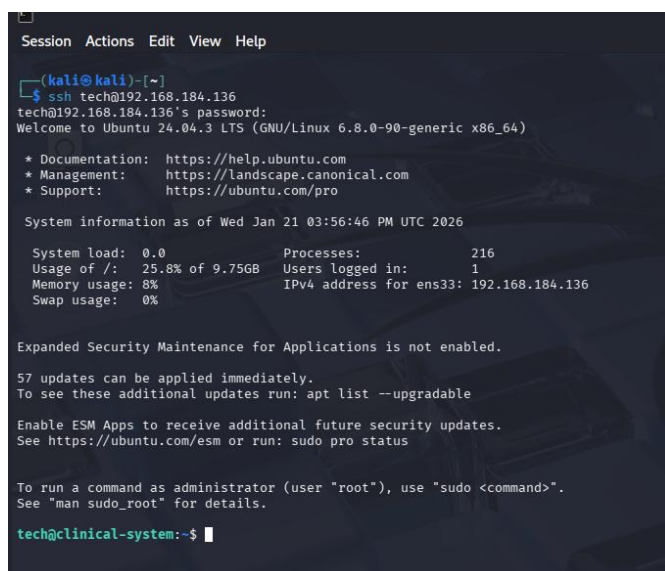
The login process was completed without additional authentication steps. No multi-factor authentication or secondary verification was observed during the connection attempt.



```
kali@kali: ~  
Session Actions Edit View Help  
  
(kali@kali)-[~]  
$ ssh tech@192.168.184.1366  
ssh: Could not resolve hostname 192.168.184.1366: Name or service not known  
  
(kali@kali)-[~]  
$ ssh tech@192.168.184.136  
The authenticity of host '192.168.184.136 (192.168.184.136)' can't be established.  
ED25519 key fingerprint is: SHA256:s4mT2jzcjW5TAVAODjuq2l616F8y+dcMQ6GiAQEqI48  
This key is not known by any other names.  
Are you sure you want to continue connecting (yes/no/[fingerprint])? y  
Please type 'yes', 'no' or the fingerprint: yes  
Warning: Permanently added '192.168.184.136' (ED25519) to the list of known hosts.  
tech@192.168.184.136's password: █
```

Figure 2: SSH login attempts from the internal workstation

Figure 2 shows the login attempt using existing credentials.



```
Session Actions Edit View Help  
  
(kali@kali)-[~]  
$ ssh tech@192.168.184.136  
tech@192.168.184.136's password:  
Welcome to Ubuntu 24.04.3 LTS (GNU/Linux 6.8.0-90-generic x86_64)  
  
* Documentation:  https://help.ubuntu.com  
* Management:    https://landscape.canonical.com  
* Support:        https://ubuntu.com/pro  
  
System information as of Wed Jan 21 03:56:46 PM UTC 2026  
  
System load:  0.0          Processes:      216  
Usage of /:   25.8% of 9.75GB  Users logged in: 1  
Memory usage: 8%          IPv4 address for ens33: 192.168.184.136  
Swap usage:  0%  
  
Expanded Security Maintenance for Applications is not enabled.  
57 updates can be applied immediately.  
To see these additional updates run: apt list --upgradable  
  
Enable ESM Apps to receive additional future security updates.  
See https://ubuntu.com/esm or run: sudo pro status  
  
To run a command as administrator (user "root"), use "sudo <command>".  
See "man sudo_root" for details.  
  
tech@clinical-system:~$ █
```

Figure 3: Active SSH session on the clinical system

Figure 3 shows the established connection after authentication.

4.4 Scenario 2: Limited Network Segmentation

The second scenario focused on network access between the internal workstation and the clinical system. Both systems were connected to the same internal network segment.

Network communication between the two systems was possible without any restrictions. The internal workstation was able to reach the clinical system directly.

No network controls were observed that limited or filtered this communication. The network allowed access between systems without additional checks.

Basic connectivity tests confirmed that the internal workstation was able to reach the clinical system without restrictions. The connection was established immediately, and no network filtering or segmentation mechanisms were observed during the communication.

This scenario shows that the network configuration allowed direct communication between internal systems and the clinical system.



```
(kali@kali)~$ ip route
default via 192.168.184.2 dev eth0 proto dhcp src 192.168.184.137 metric 100
192.168.184.0/24 dev eth0 proto kernel scope link src 192.168.184.137 metric 100

(kali@kali)~$ ping -c 5 192.168.184.136
PING 192.168.184.136 (192.168.184.136) 56(84) bytes of data:
64 bytes from 192.168.184.136: icmp_seq=1 ttl=64 time=1.24 ms
64 bytes from 192.168.184.136: icmp_seq=2 ttl=64 time=1.58 ms
64 bytes from 192.168.184.136: icmp_seq=3 ttl=64 time=0.691 ms
64 bytes from 192.168.184.136: icmp_seq=4 ttl=64 time=0.518 ms
64 bytes from 192.168.184.136: icmp_seq=5 ttl=64 time=1.40 ms

— 192.168.184.136 ping statistics —
5 packets transmitted, 5 received, 0% packet loss, time 4052ms
rtt min/avg/max/mdev = 0.518/1.084/1.582/0.410 ms

(kali@kali)~$ ssh tech@192.168.184.136
tech@192.168.184.136's password:
Welcome to Ubuntu 24.04.3 LTS (GNU/Linux 6.8.0-90-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/pro

System information as of Wed Jan 21 04:39:38 PM UTC 2026

System load:  0.2               Processes:    212
Usage of /:   25.9% of 9.75GB   Users logged in: 0
Memory usage: 7%              IPv4 address for ens33: 192.168.184.136
Swap usage:  0%

Expanded Security Maintenance for Applications is not enabled.

57 updates can be applied immediately.
To see these additional updates run: apt list --upgradable

Enable ESM Apps to receive additional future security updates.
See https://ubuntu.com/esm or run: sudo pro status

Last login: Wed Jan 21 15:56:46 2026 from 192.168.184.137
tech@clinical-system:~$
```

Figure 4: Direct network communication between the internal workstation and the clinical system

Figure 4 shows that the internal workstation was able to communicate directly with the clinical system.

4.5 Scenario 3: Limited Detection

The third scenario focused on how access to the clinical system was detected. The access was written to the system logs. The log entry recorded the time of the access and the user account used for the login attempt. However, the system did not generate any active alert or notification when the access occurred. There was nothing to indicate that the activity was noticed at the time. The system did not respond to the access attempt. It continued to work as normal before, during, and after the access. This scenario shows that access to the clinical system was logged but not actively noticed in the current setup.

```
Last login: Wed Jan 21 15:56:46 2020 from 192.168.184.137
tech@clinical-system:~$ sudo journalctl -n 20
[sudo] password for tech:
Jan 21 19:59:18 clinical-system systemd[1]: Starting fwupd.service - Firmware update daemon ...
Jan 21 19:59:18 clinical-system dbus-daemon[805]: [system] Activating via systemd: service name='org.freedesktop.UPower' unit='upower.service' requested by ':1.15' (uid=0 pid=1279 comm="/usr/
Jan 21 19:59:18 clinical-system systemd[1]: Starting upower.service - Daemon for power management ...
Jan 21 19:59:18 clinical-system dbus-daemon[805]: [system] Successfully activated service 'org.freedesktop.UPower'
Jan 21 19:59:18 clinical-system systemd[1]: Started upower.service - Daemon for power management.
Jan 21 19:59:18 clinical-system fwupd[1279]: 19:59:18.778 FuEngine failed to add device /sys/devices/pci0000:00/0000:00:11.0/0000:02:04.0/ata4/host3/target3:0:0/3:0:0:0/block/sr
Jan 21 19:59:18 clinical-system fwupd[1279]: 19:59:18.812 FuMain fwupd 1.9.30 ready for requests (locale en_US.UTF-8)
Jan 21 19:59:18 clinical-system dbus-daemon[805]: [system] Successfully activated service 'org.freedesktop.fwupd'
Jan 21 19:59:18 clinical-system systemd[1]: Started fwupd.service - Firmware update daemon.
Jan 21 19:59:18 clinical-system systemd[1]: fwupd-refresh.service: Deactivated successfully.
Jan 21 19:59:18 clinical-system systemd[1]: Finished fwupd-refresh.service - Refresh fwupd metadata and update motd.
Jan 21 20:00:22 clinical-system systemd[1]: Starting sysstat-collect.service - system activity accounting tool ...
Jan 21 20:00:22 clinical-system systemd[1]: sysstat-collect.service: Deactivated successfully.
Jan 21 20:00:22 clinical-system systemd[1]: Finished sysstat-collect.service - system activity accounting tool.
Jan 21 20:05:01 clinical-system CRON[1300]: pam_unix(cron:session): session opened for user root(uid=0) by root(uid=0)
Jan 21 20:05:01 clinical-system CRON[1301]: (root) CMD (command -v debian-sa1 > /dev/null && debian-sa1 1 1)
Jan 21 20:05:01 clinical-system CRON[1300]: pam_unix(cron:session): session closed for user root
Jan 21 20:06:50 clinical-system sudo[1304]: tech : TTY=pts/0 ; PWD=/home/tech ; USER=root ; COMMAND=/usr/bin/journalctl -n 20
Jan 21 20:06:50 clinical-system sudo[1304]: pam_unix(sudo:session): session opened for user root(uid=0) by tech(uid=1000)
Jan 21 20:06:50 clinical-system systemd[1]: Starting fwupd-refresh.service - Refresh fwupd metadata and update motd ...
lines 1-20/20 (END)
```

Figure 5: SSH login recorded in system logs

Figure 5 shows the access activity recorded in the system log.

4.6 Summary of Findings

This chapter presented the findings from the proof-of-concept simulation. The results were based on observations made during the practical work.

The findings showed that internal access to the clinical system was possible using existing user login details. Access was gained without additional security checks.

It was also observed that the internal workstation and the clinical system were able to communicate directly over the same network. No network controls were in place to limit this communication.

In addition, access activity was recorded in the system logs, but no active detection or alerts were observed during the access. The system continued to operate normally throughout the

process.

These findings give a clear overview of the security conditions observed in the simulated environment. These observations reflect vulnerabilities frequently described in healthcare cybersecurity research (European Union Agency for Cybersecurity, 2023) (OWASP Foundation, 2022). The implications of these results are discussed in the next chapter.

5. Discussion

5.1 Introduction

This chapter looks at what the proof-of-concept findings mean in practice and how they relate to existing research on healthcare cybersecurity.

The simulation showed that internal access, limited network segmentation and weak monitoring can create real security risks in connected healthcare environments (European Union Agency for Cybersecurity, 2023). These are not purely technical problems. They are shaped by how clinical systems are used day to day, and by the constraints that come with keeping those systems running continuously during patient care.

Clinical environments operate differently from standard IT settings. Taking systems offline is rarely an option, vendors have to be involved in most changes, and what works in standard IT does not always fit in a hospital (National Institute of Standards and Technology, 2022).

Known weaknesses often stay in place longer than anyone would want, even when the risks are well understood (European Union Agency for Cybersecurity, 2023). The simulation reflected this, the issues that came up are the same ones that keep appearing in real healthcare environments. The next sections go through each scenario in turn.

5.2 Discussion of Scenario 1 – Internal Access

The simulation showed that the clinical system could be reached from an internal workstation using existing credentials. Nobody was asked for a second form of verification, and the login went straight through. This reflects the vulnerabilities identified in the literature and shows how they can be exploited in practice in healthcare environments.

This kind of situation keeps coming up in healthcare cybersecurity research, where stolen or misused internal credentials are behind a lot of incidents (Kumar, et al., 2023). This matters because it shows that internal access is not only a theoretical risk, but a practical issue that can affect real systems used in patient care.

Access control in healthcare gets shaped by how clinical work actually runs. Staff need to get into systems fast, and anything that slows that down tends to get bypassed or switched off. Multi-factor authentication often falls into that category. This suggests that vulnerabilities in authentication are not only technical weaknesses but are also influenced by operational requirements.

If an account gets misused, there is not much standing in the way of someone reaching systems used for patient monitoring, diagnostics or treatment. That is where the real risk sits (European Union Agency for Cybersecurity, 2023). This highlights how vulnerabilities identified in the literature (RQ1) can directly contribute to real-world risks and potential incidents (RQ2).

This tension is not new. Healthcare organisations have never found it easy to balance security with keeping systems running (National Institute of Standards and Technology, 2022). Older systems and limited resources just make that harder. This suggests that existing security frameworks may not fully account for these operational constraints in practice (RQ3).

Access rights also tend to drift over time. People move between roles, systems get shared across shifts, and access rights rarely get a second look. Over time that adds up (National Institute of Standards and Technology, 2022). When someone is inside the network, their activity does not always get looked at closely either. Access can carry on unnoticed, which ties into the monitoring issues covered in section 5.4.

The bigger problem is not just that stronger authentication is missing. Getting it in place in a clinical environment is harder than it sounds. Change how staff log in and you slow them down, which in a hospital is not a small thing. So most places just leave it as it is (European Union Agency for Cybersecurity, 2023). This shows that improving security in healthcare requires solutions that fit within existing workflows, rather than approaches that assume full flexibility.

5.3 Discussion of Scenario 2 – Network Segmentation

The simulation showed that systems on the same network could communicate directly without any restrictions in place. This is something that also appears in healthcare cybersecurity research, where limited or partial segmentation is often found in hospital environments (European Union Agency for Cybersecurity, 2022) (European Union Agency for Cybersecurity, 2023). In this case, it was clear that the network structure allowed systems to interact more freely than expected, which points to weaknesses in how segmentation is actually implemented.

The reason it stays that way is not hard to understand. Clinical systems depend on constant communication. Patient monitoring, diagnostics and treatment systems all rely on stable connections to function properly. If segmentation is too strict, it can interrupt these processes. Changes to network architecture can also introduce risks to system availability that are difficult to predict (European Union Agency for Cybersecurity, 2023). Because of this, stronger segmentation is not always prioritised, even when the risks are known.

Hospital networks also tend to grow over time rather than being built in a structured way from the beginning. New systems are added to existing infrastructure, and older and newer technologies end up working side by side. Over time, this makes the network harder to control and organise. Segmentation may have been planned earlier, but as the environment changes, it is not always fully applied in practice. This suggests that vulnerabilities are often linked to long-term operational and organisational factors, not just technical design.

When segmentation is not in place, an attacker who has got into one part of the network can move between systems without much standing in the way. That increases the potential damage from a single point of entry considerably. This reflects how vulnerabilities can be exploited in real incidents (RQ2), where lateral movement across systems is a common attack method.

The standard advice to segment networks is not wrong, but in healthcare it needs to be applied carefully. A blanket approach does not account for how dependent clinical systems are on network communication. In practice, segmentation tends to get introduced gradually, which means parts of the environment stay more exposed for longer than intended (European Union

Agency for Cybersecurity, 2023). This suggests that existing frameworks and best practice recommendations may not fully address the complexity of healthcare environments in practice (RQ3).

5.4 Discussion of Scenario 3 – Detection and Monitoring

The simulation logged the access, but nothing flagged it. No alert, no notification, just the system carrying on as normal. That is not unusual in healthcare, and it reflects how monitoring tends to work in these environments in practice (European Union Agency for Cybersecurity, 2023).

Log data gets collected across clinical systems, servers and medical devices, but reviewing it regularly is another matter entirely. Healthcare organisations sit on huge amounts of log data. Staff are busy, and going through logs is usually the first thing that gets dropped when something more pressing comes up (European Union Agency for Cybersecurity, 2023). The data is there, but nobody is going through it.

Monitoring tools bring their own problems on top of that. They need setting up properly, they need ongoing maintenance, and in some cases they can affect how clinical systems perform. In environments where keeping systems stable and available comes before almost everything else, that is often enough reason to avoid them altogether (National Institute of Standards and Technology, 2023).

There is also the question of process. Even where logs are available, staff do not always know what to look for or when to check them. Without a clear process in place, logging becomes a record of what happened rather than something that actually helps catch problems while they are happening. The value of logging as a security measure drops considerably without that active layer on top of it. The gap between collecting data and acting on it is where the real risk sits. An organisation can have full logging enabled across every system and still miss an incident entirely if nobody is watching. In practice, detection usually comes down to someone stumbling across something. If that does not happen, it does not get caught. By the time anything surfaces, a lot of time has already passed, and the damage is harder to undo.

This shows how weaknesses in monitoring can allow vulnerabilities to go unnoticed and increase the risk of real incidents in healthcare environments.

5.5 Implications for Healthcare Organisations

The findings point to something that goes beyond individual technical weaknesses.

Cybersecurity risks in healthcare are shaped by how systems are used in practice, what constraints organisations work under, and how much flexibility they actually have when it comes to making changes (European Union Agency for Cybersecurity, 2023). A vulnerability does not exist on its own. It exists inside a system that has to keep running, managed by staff who have other priorities, in an organisation that depends on vendors for fixes.

Existing frameworks offer guidance, but they tend to be written for environments where systems can be patched, isolated or reconfigured without too much trouble. Healthcare is rarely like that. System availability, older infrastructure and vendor dependencies all affect what is actually possible, and those factors do not always get the attention they deserve in regulatory documents (National Institute of Standards and Technology, 2022). Meeting the requirements on paper does not always mean the underlying risks have been dealt with.

This matters because security measures that do not fit how an environment actually works tend not to get used. Staff work around them, they get switched off, or they never get properly set up in the first place. A control that creates friction in a clinical setting is likely to be the first thing that goes when things get busy.

What the findings suggest is that improvements do not always need to be complex to make a difference. Small, targeted changes that fit around how systems already work are more likely to be applied and maintained than controls that require significant disruption to put in place. Getting the basics right in a way that suits the environment is more useful than trying to implement something ideal that never quite lands in practice (European Union Agency for Cybersecurity, 2023).

The following sections look at what that means in practice for internal access, network segmentation and detection and monitoring.

5.5.1 Internal Access

The simulation showed that getting into the clinical system took nothing more than existing credentials. No extra checks, no second step. That kind of setup tends to stick around because tightening access controls can slow staff down, and in a clinical environment that matters (National Institute of Standards and Technology, 2022).

The risks are usually not a secret. Most organisations know where the gaps are. Acting on that is the hard part. Changes that fit around how staff already work are far more likely to get used than anything that requires a big overhaul nobody has the time for (National Institute of Standards and Technology, 2023).

5.5.2 Network Segmentation

The simulation showed that systems on the same network could communicate directly without restrictions. Flat or shared network structures are not unusual in healthcare, partly because clinical systems often need to talk to each other to function properly (National Institute of Standards and Technology, 2023).

Full segmentation is not always realistic. Strict separation can affect how systems operate, and in a clinical environment that is not a risk organisation can easily take. Separating clinical systems from administrative ones where possible is a more practical starting point than trying to segment everything at once (European Union Agency for Cybersecurity, 2023).

Healthcare networks tend to grow over time rather than being redesigned from scratch. Older and newer systems end up connected together, and making structural changes to that becomes increasingly difficult. Segmentation is therefore something that usually has to be introduced gradually, fitted around how systems already communicate rather than imposed on top of them (European Union Agency for Cybersecurity, 2023).

5.5.3 Detection and Monitoring

The access got logged, but nothing picked it up. That is pretty common in healthcare. Logs are there, but going through them regularly is another matter (European Union Agency for Cybersecurity, 2023).

The sheer amount of data coming from clinical systems, servers and medical devices makes active monitoring hard to keep up with. Time and staff are both in short supply. Concentrating on the most critical systems first is more realistic than trying to cover everything at once, and even fairly basic monitoring can make a difference without making systems harder to manage (National Institute of Standards and Technology, 2022)

Logs sitting in storage do not make anything safer. Someone has to actually look at them.

5.6 Limitations of the Study

The main limitation of this study is the simulation itself. It was carried out in a small virtual environment that does not come close to reflecting the complexity of a real hospital network. Real healthcare infrastructure involves legacy systems, multiple network segments, vendor constraints and a lot of moving parts that were simply outside the scope of this setup (National Institute of Standards and Technology, 2022).

The three scenarios also cover a narrow slice of the problem. Internal access, network segmentation and monitoring are all relevant, but there is a lot that was not looked at, including incident response processes, advanced security tooling and the human factors that shape how security works in practice. No real healthcare organisations were involved, and no live systems or patient data were used. No real systems were used, which was the right decision, but it does limit how far the findings stretch. A lab is not a hospital. The conditions observed in the simulation did line up with what previous research has reported though (European Union Agency for Cybersecurity, 2023), which suggests the setup was not too far off the mark.

Future work could look at these questions in larger environments, or through direct collaboration with healthcare organisations where that is possible.

5.7 Evaluation of the Proof-of-Concept

The simulation held up. Each scenario showed what it was meant to show, and none of it needed anything complex to pull off.

Scenario 1 showed that getting into the clinical system took nothing more than existing credentials. No second step, no alert. That is consistent with what keeps coming up in the

literature about healthcare authentication practices (European Union Agency for Cybersecurity, 2023). What this also suggests is that the literature identifies the problem clearly enough, but offers little on how to actually fix it in environments where clinical speed takes priority.

Scenario 2 showed that systems on the same network could talk to each other without any restrictions in place. That also matched what has been reported about flat or shared network structures in hospitals (European Union Agency for Cybersecurity, 2022).

In a real environment, that kind of setup makes it easier to move between systems once access has been established somewhere.

Scenario 3 confirmed that access got logged but nothing picked it up. Logs existed, but they were not being watched. That is exactly what the literature describes, and the simulation reflected it clearly (OWASP Foundation, 2022).

Keeping it small was the right call. It meant each scenario could be followed clearly without too much else going on. That said, a lab environment is not a hospital. Real healthcare networks are far more complex, with legacy systems, vendor dependencies and certification requirements that were all outside the scope of this setup. The findings cannot be applied directly to real environments because of that. It is also worth noting that the scenarios were designed around vulnerabilities already identified in the literature. A more independent simulation might have uncovered issues that existing research has not yet captured.

The three scenarios also only covered a slice of the problem. Patch management, physical security and incident response were not tested, and a more complete simulation would have looked at those too. But adding more complexity would have made the results harder to follow.

Despite these limits, the simulation added something that the literature review alone could not. It showed that these vulnerabilities can appear in practice, not just in theory, and it gave a concrete basis for the framework evaluation that followed.

6. Conclusion

This dissertation looked at cybersecurity challenges in healthcare, focusing on internal access, network segmentation and detection and monitoring. The aim was to understand how these issues play out in practice and where existing research and security frameworks fall short.

The first research question was about what vulnerabilities are common in healthcare OT and IoMT systems. The literature keeps pointing to the same things: weak authentication, limited segmentation, delayed patching and poor monitoring. The fact that these keep coming up across different settings suggests they are part of how these environments work, not just occasional oversights.

The second research question looked at how incidents have actually used these vulnerabilities. WannaCry in 2017 is hard to ignore here. Unpatched systems allowed the attack to spread across connected infrastructure, and hospitals had to rely on manual processes to keep going (National Audit Office, 2017). One attack was enough to cause major disruption across parts of the NHS.

The third research question looked at whether existing frameworks cover OT and IoMT risks well enough. NIS2, GDPR, MDR, ISO 27001 and NIST all touch on parts of it, but none of them are designed specifically for clinical environments. They often assume that systems can be updated or taken offline when needed, which in healthcare is rarely the case (National Institute of Standards and Technology, 2022).

The final research question focused on whether these vulnerabilities can be demonstrated in practice. The simulation showed that internal access, weak segmentation and limited monitoring can all be reproduced, even in a small controlled setup. This gives a clearer picture of how these issues might appear in real environments

The findings overall make one thing clear. These are not purely technical problems. They are shaped by how healthcare systems are used day to day. Systems have to stay running, changes are difficult to introduce, and known risks often remain because the environment makes them hard to fix.

The study also looked at what this means in practice. Not ideal solutions, but realistic ones. Reviewing access rights, introducing segmentation where possible, and making better use of logs that already exist can all make a difference without causing major disruption.

The simulation had its limits. It was a small controlled environment and real hospital networks are far more complex. Because of this, the findings cannot be generalised too broadly.

Current frameworks do not always match how clinical environments actually work, and that gap is not going to close by adding more technical controls. Understanding how security, operations and regulation pull in different directions in practice is likely where further research could be most useful (European Union Agency for Cybersecurity, 2023).

References

- Albert, W., 2014. The power of qualitative methods. *UXPA Magazine*.
- Creswell, J. W. & Creswell, J. D., 2018. *Research Design: Qualitative, Quantitative, and Mixed Methods Approaches*. 5 ed. Thousand Oaks, CA: SAGE Publications.
- European Union Agency for Cybersecurity, 2023. *ENISA Threat Landscape: Health Sector*, s.l.: s.n.
- European Union Agency for Cybersecurity, 2022. *ENISA Threat Landscape 2022*, s.l.: s.n.
- European Union, 2016. *Regulation (EU) 2016/679 (GDPR)*. [Online]
Available at: <https://eur-lex.europa.eu/eli/reg/2016/679/oj>
[Accessed 26 12 2025].
- European Union, 2017. *Regulation (EU) 2017/745 (Medical Device Regulation)*. [Online]
Available at: <https://eur-lex.europa.eu/eli/reg/2017/745/oj>
[Accessed 27 12 2025].
- European Union, 2022. *Directive (EU) 2022/2555 (NIS2 Directive)*. [Online]
Available at: <https://eur-lex.europa.eu/eli/dir/2022/2555/oj>
[Accessed 26 12 2025].
- International Organization for Standardization, 2022. *ISO/IEC 27001:2022 – Information security management*. [Online]
Available at: <https://www.iso.org/standard/27001>
[Accessed 26 12 2025].
- Kitchenham, B. a. C. S., 2007. *uidelines for performing systematic literature reviews in software engineering*, s.l.: s.n.
- Kumar, M., Marchang, N. & Tripathi, A., 2023. Security and privacy challenges in Internet of Medical Things: A comprehensive survey. *Computer Communications*, pp. 1-23.
- National Audit Office, 2017. *Investigation: WannaCry cyber attack and the NHS*. [Online]
Available at: <https://www.nao.org.uk/reports/investigation-wannacry-cyber-attack-and-the-nhs/>
[Accessed 23 12 2025].
- National Institute of Standards and Technology, 2008. *Technical Guide to Information Security Testing and Assessment*, s.l.: U.S. Department of Commerce.

National Institute of Standards and Technology, 2022. *Cybersecurity Framework Profile for the Healthcare and Public Health Sector*, s.l.: s.n.

National Institute of Standards and Technology, 2023. *NIST Special Publication 800-82 Revision 3: Guide to Operational Technology Security*, s.l.: s.n.

OWASP Foundation, 2022. *OWASP Internet of Things Project*. [Online]
Available at: <https://owasp.org/www-project-internet-of-things/>
[Accessed 22 12 2025].

U.S. Food and Drug Administration, 2023. *Cybersecurity*. [Online]
Available at: <https://www.fda.gov/medical-devices/digital-health-center-excellence/cybersecurity>
[Accessed 20 12 2025].

Yin, R. K., 2018. *Case Study Research and Applications: Design and Methods*. 6 ed.
Thousand Oaks, CA: SAGE Publications.